

Security Standards & Data Protection Report

Forma User Management Application

Prepared by: Digibuild Report Date: 8 October 2026 Application Version: v2.4.0

Classification: Confidential

1. Data Processed

The application processes the following categories of personal and operational data:

Data Category	Examples	Storage Location	Encrypted
User Identity	Name, email address	Google Firestore (cloud)	✓ AES-256-GCM at rest
Authentication Credentials	Hashed passwords, JWT tokens	Firebase Authentication	✓ Firebase managed encryption
Access Tokens	Autodesk API access tokens (2-legged and 3-legged)	Server memory / browser memory only (not persisted)	✓ In-memory only, never written to disk or storage
Refresh Tokens	Autodesk OAuth refresh tokens (for silent reconnection)	Google Firestore (cloud)	✓ AES-256-GCM at rest; never sent to or held in the browser
User/Company Lists	Imported user lists, companies, roles (per tenant)	Google Firestore (cloud)	✓ AES-256-GCM at rest
Folder Permissions	Folder access levels and grants	Autodesk Forma API only — not persisted in this app	✓ TLS in transit; nothing stored at rest here

Data Category	Examples	Storage Location	Encrypted
Activity Log	Changes made in Autodesk Forma through the app: who made them, affected members, companies, roles, projects and folders	Google Firestore (cloud), one record per change, deleted automatically after 12 months	✓ AES-256-GCM at rest (names, emails, project/folder names, details); only date, tool and activity type are stored in clear for sorting and filtering
Audit Logs	Login timestamps, IP addresses, action logs	Server logs (VM)	✓ Access-restricted VM storage

Data Minimisation: The application collects only the personal data strictly necessary to manage project user permissions. No financial data, health data, or special categories of personal data (as defined by GDPR Article 9) are processed.

2. Encryption & Data Protection

Encryption at Rest

- **Algorithm:** AES-256-GCM (authenticated encryption — ciphertext integrity is cryptographically verified on every read, tampered data is rejected rather than silently decrypted)
- **Key derivation:** scrypt, combined with a dedicated server-side encryption secret plus a unique random salt per record (activity log: one random salt per tenant account, with a fresh IV and authentication tag per entry)
- **IV:** Fresh random Initialisation Vector for every encryption operation
- **Storage:** Encrypted ciphertext, salt, IV and authentication tag stored in Firestore; the encryption secret is never stored alongside the data it protects
- **Key management:** Encryption key stored as environment variable, never hardcoded

Encryption in Transit

- **Protocol:** TLS 1.2 / 1.3 (HTTPS only in production)
- **HSTS:** Strict-Transport-Security max-age=31,536,000; includeSubDomains; preload
- **Upgrade policy:** CSP upgrade-insecure-requests directive enforces HTTPS
- **API traffic:** All calls to Autodesk Forma API over HTTPS
- **Firebase:** WebSocket over WSS (encrypted WebSocket)

Firestore (Google Cloud) Encryption

Google Cloud Firestore automatically encrypts all data at rest using AES-256 and all data in transit using TLS. This is in addition to the application-level AES-256-GCM authenticated encryption applied before data reaches Firestore —

providing double-layer encryption, with integrity verification, for sensitive fields.

Secret / Key Storage

No credentials, API keys, or encryption keys are hardcoded in source code. All secrets are injected at runtime via OS environment variables and excluded from version control via `.gitignore`. The application fails with a fatal error on startup if any required secret is missing.

3. Authentication & Access Control

Control	Implementation
✓ Firestore Authentication	Industry-standard identity platform (Google) with email / password authentication
✓ Email Verification	Enforced server-side on every endpoint that issues Autodesk tokens or reads/writes stored data, not only at sign-in — non-admin accounts with an unverified email, or an expired trial or license, are refused (HTTP 403)
✓ JWT Token Authentication	All API requests authenticated using short-lived JSON Web Tokens issued by Firebase
✓ Firestore App Check (reCAPTCHA v3)	Prevents automated / bot access to Firestore backend resources
✓ Role-Based Access Control (RBAC)	Admin and standard user roles enforced entirely server-side: every admin-only endpoint independently re-verifies the caller's Firestore ID token and checks their admin status against Firestore via the Admin SDK before acting
✓ No Client-Side Database Access	The browser never communicates with Firestore directly — no Firestore SDK is loaded on any page. Every data operation goes through an authenticated server-side endpoint, which performs its own authorization before touching the database. This removes reliance on separately-configured, client-facing database rules as a security boundary
✓ Per-User Data Isolation	Multi-tenant architecture — every server-side query and write is scoped to the requesting user's own verified ID (from their Firestore token), so one user's data is never reachable from another user's session
✓ No Client-Side Credential Storage	Session tokens are never written to localStorage or sessionStorage. The Autodesk API client secret is never sent to or held in the browser at all — the OAuth token exchange is performed entirely server-side. Application-level (2-legged) Autodesk tokens are never issued to the browser; the browser only ever holds the signed-in user's own Autodesk token

Control		Implementation
✓	OAuth State Parameter Validation	A cryptographically random state value is generated and verified before any authorization code is exchanged, protecting the Autodesk login flow against cross-site request forgery

4. Application Security — OWASP Top 10 Compliance

The following table maps the OWASP Top 10 (2021) vulnerability categories to the controls implemented in the application.

OWASP Category	Status	Controls in Place
✓ A01 — Broken Access Control	MITIGATED	Server-side admin middleware re-verifies caller identity and role on every request; email verification and license/trial status are re-checked server-side on every working endpoint; no client-side database access exists; per-user data isolation enforced by scoping every query/write to the caller's own verified ID. Autodesk account-level operations run server-side with an application token that never reaches the browser, and only for Forma accounts in which the signed-in Autodesk user is verified (via Autodesk) to be an active member; only fixed operations and fields are forwarded
✓ A02 — Cryptographic Failures	MITIGATED	AES-256-GCM authenticated encryption with script key derivation from a dedicated server-side secret; TLS 1.2/1.3; HSTS enforced; the Autodesk API client secret is never transmitted to or held in the browser
✓ A03 — Injection / XSS	MITIGATED	Data originating outside the application (Autodesk project, hub, folder, company and role names; purchaser and user emails shown in the admin panel) is either rendered via safe DOM APIs (textContent, addEventListener, element properties) or passed through escapeHtml(), which escapes & < > " ' so output is safe both as element content and inside quoted HTML attributes. No inline event handlers are built from external data. Purchase emails containing < > " \ are rejected server-side. A re-audit on 29 September 2026 found and fixed attribute-context and admin-panel insertion points missed by the previous pass; every remaining dynamic insertion interpolates only escaped values or trusted internal values (counts, timestamps, fixed labels, Autodesk-generated IDs).
✓ A04 — Insecure Design	MITIGATED	Threat-modelled architecture; secrets management via environment variables; no debug endpoints in production
✓ A05 — Security Misconfiguration	MITIGATED	Comprehensive security headers (7 headers active); CORS restricted to allowed origins; no default credentials; static file serving is scoped exclusively to a dedicated public assets directory — server-side configuration and credential files are never web-accessible

	OWASP Category	Status	Controls in Place
!	A06 — Vulnerable Components	IN PROGRESS	Dependencies tracked in <code>package.json</code> / <code>package-lock.json</code> . An npm audit on 29 September 2026 reported known advisories in production dependencies (mostly transitive, via <code>firebase-admin</code> , <code>express</code> , <code>axios</code> and <code>nodemailer</code>); updating them is scheduled, with each update verified against the production Node.js runtime before release
✓	A07 — Auth & Session Failures	MITIGATED	Firebase-managed auth; short-lived JWTs; enforced email verification before login; rate limiting on server authentication endpoints (20 requests / 15 min per IP; password sign-in itself is throttled by Firebase Authentication); CSRF-protected OAuth flow via validated state parameter
✓	A08 — Software Integrity Failures	MITIGATED	CSP restricts script sources to explicit whitelist; external resources loaded from HTTPS CDNs only; Subresource Integrity (SRI) hashes verify every externally-loaded script matches its expected content before execution
✓	A09 — Logging & Monitoring Failures	MITIGATED	Request logging with IP tracking; authentication event logging; error logging (non-verbose to users)
✓	A10 — Server-Side Request Forgery	MITIGATED	Server only makes outbound requests to whitelisted Autodesk and Google endpoints; no user-controlled URL parameters passed to backend fetch calls

5. HTTP Security Headers

All production responses include the following security headers, providing defence-in-depth against common browser-based attacks:

	Header	Value / Description
✓	Strict-Transport-Security	<code>max-age=31536000; includeSubDomains; preload</code> — Forces HTTPS for 1 year across all subdomains
✓	Content-Security-Policy	Strict policy with <code>default-src 'self'</code> ; <code>frame-ancestors 'none'</code> ; <code>form-action 'self'</code> ; <code>object-src 'none'</code> ; <code>upgrade-insecure-requests</code>
✓	X-Frame-Options	DENY — Prevents clickjacking by disallowing the application from being embedded in any iframe
✓	X-Content-Type-Options	<code>nosniff</code> — Prevents MIME-type sniffing attacks

Header	Value / Description
✓ X-XSS-Protection	1; mode=block — Activates browser's built-in XSS filter
✓ Referrer-Policy	strict-origin-when-cross-origin — Limits referrer information sent to third parties
✓ Permissions-Policy	geolocation=(), microphone=(), camera=() — Disables access to sensitive browser APIs not required by the application

6. Infrastructure & Hosting Security

Hosting Environment

- **Provider:** Google Cloud Platform (VM)
- **Region:** European data centre
- **Domain:** usermgt.digibuild.ch (HTTPS)
- **Process manager:** PM2 (auto-restart, single instance)
- **OS firewall:** Only ports 80 and 443 reachable from the internet; the application port (3000) is reachable only through the reverse proxy

Database — Google Firestore

- **Provider:** Google Firebase / Firestore
- Managed, serverless NoSQL database
- Automatic replication & backups
- AES-256 encryption at rest (Google-managed)
- TLS 1.3 encryption in transit
- SOC 1, SOC 2, ISO 27001 certified

Rate Limiting & DoS Protection

- **Global API:** 100 requests / 15 minutes per IP
- **Login / registration endpoints:** 20 requests / 15 minutes per IP
- **Client identification:** the connecting IP as recorded by the reverse proxy; client-supplied forwarding headers are not trusted
- **License purchase endpoints:** 10 requests / 15 minutes per IP
- **Algorithm:** Redis-backed sliding window when Redis is configured; otherwise a per-instance in-memory fixed window (single instance in production)
- **Behaviour:** Returns HTTP 429 on breach

Network & CORS Controls

- CORS restricted to explicitly whitelisted origins only (production: the application domain only)
- No wildcard (*) origin is ever sent; requests without an Origin header receive no CORS headers
- Credentials flag enabled only for allowed origins
- Preflight requests validated server-side
- HTTP→HTTPS redirect active in production

Google Cloud & Firebase Security Certifications: The underlying infrastructure (Google Cloud Platform and Firebase) holds the following certifications: **ISO/IEC 27001, SOC 1 Type II, SOC 2 Type II, SOC 3, PCI DSS, FedRAMP** and more. Full details: cloud.google.com/security/compliance and firebase.google.com/support/privacy.

7. Known Limitations & Roadmap

Item	Status	Risk Level	Mitigation / Plan
Firestore SDK requires <code>unsafe-inline</code> / <code>unsafe-eval</code> in the script CSP	ACCEPTED	Low (documented Firebase limitation)	All other CSP directives are strict; external data is escaped or set via safe DOM APIs so the relaxed script directives are not relied on for XSS protection

8. Security Controls Summary

Control Domain	Status
✓ AES-256-GCM authenticated encryption at rest (application layer)	ACTIVE
✓ AES-256 encryption at rest (Firestore / GCP layer)	ACTIVE
✓ TLS 1.2/1.3 encryption in transit	ACTIVE
✓ HSTS (HTTP Strict Transport Security)	ACTIVE
✓ Firebase Authentication (industry-standard)	ACTIVE
✓ Email verification enforced before login (non-admin accounts)	ACTIVE
✓ JWT token-based session management	ACTIVE
✓ Firebase App Check (reCAPTCHA v3 bot protection)	ACTIVE
✓ Role-Based Access Control (RBAC)	ACTIVE
✓ No client-side database access (server-side-only, via authenticated endpoints)	ACTIVE
✓ CORS restricted to whitelisted origins	ACTIVE

Control Domain	Status
✓ Rate limiting (API + authentication endpoints)	ACTIVE
✓ 7 HTTP security headers (CSP, HSTS, X-Frame-Options, etc.)	ACTIVE
✓ XSS protection (escapeHtml + safe DOM rendering of external data + CSP)	ACTIVE
✓ Clickjacking protection (X-Frame-Options: DENY + CSP frame-ancestors)	ACTIVE
✓ Subresource Integrity (SRI) on all externally-loaded scripts	ACTIVE
✓ Request logging with IP tracking	ACTIVE
✓ Secrets management via environment variables (no hardcoded keys)	ACTIVE
✓ Server-side OAuth token exchange (Autodesk client secret never exposed to the browser)	ACTIVE
✓ Autodesk refresh tokens encrypted at rest (AES-256-GCM), never exposed to the browser	ACTIVE
✓ OAuth state parameter validation (CSRF protection on login flow)	ACTIVE
✓ Static asset serving scoped to a dedicated public directory	ACTIVE
✓ Per-user data isolation (multi-tenant)	ACTIVE